

Entra ID Conditional Access Lab

Enterprise Identity Security Framework — Microsoft Entra ID Premium P2

Oluwaseyi Michael Falode | Cybersecurity & Cloud Security Engineer | Toronto, ON

github.com/seyifalode-cmd | linkedin.com/in/oluwaseyi-falode

Project Overview

This lab demonstrates how to design, deploy, and validate a Conditional Access policy framework from scratch using Microsoft Entra ID Premium P2. The policies cover the core security scenarios a financial institution like Scotiabank would enforce across its user population — standard employees, IT administrators, and external vendors.

All policies were deployed in Report-only mode following enterprise change management best practices, then validated using the built-in What If analysis tool before any enforcement.

Environment

Component	Details
Platform	Microsoft Azure / Microsoft Entra ID
License	Microsoft Entra ID Premium P2
User Personas	Standard Employee, IT Administrator, External Vendor
Groups Created	CA-Standard-Employees, CA-IT-Administrators, CA-External-Vendors
Policy Mode	Report-only (pre-enforcement validation)
Policies Built	5 Conditional Access policies

Identity Structure

Three security groups were created to segment users by role and risk level. Conditional Access policies target groups because this is the only approach that scales in an enterprise environment.

Group Name	Member	Purpose
CA-Standard-Employees	Test Employee	Standard staff with everyday app access
CA-IT-Administrators	Test Admin	Privileged accounts with elevated system access
CA-External-Vendors	Test Vendor	External contractors with limited app access

Screenshots — Identity Setup

Users — All Test Accounts

All three test user accounts created in the tenant representing the three user personas.

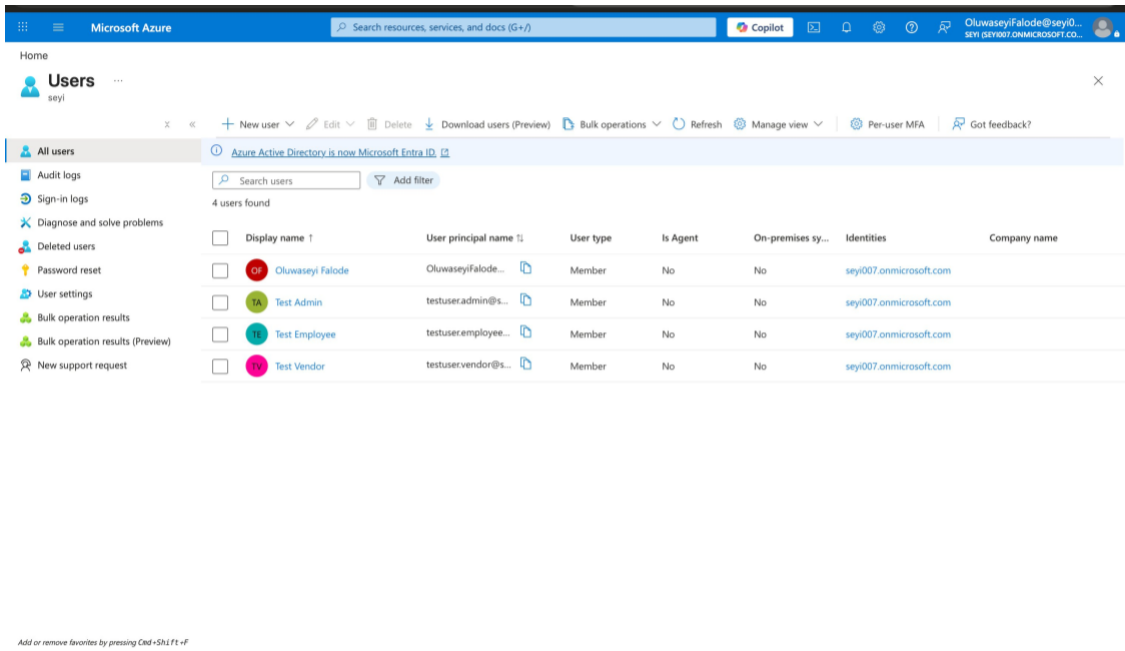


Figure 1 — Test users: Test Employee, Test Admin, Test Vendor

Security Groups

Three security groups created with Assigned membership type, each targeting a different user risk profile.

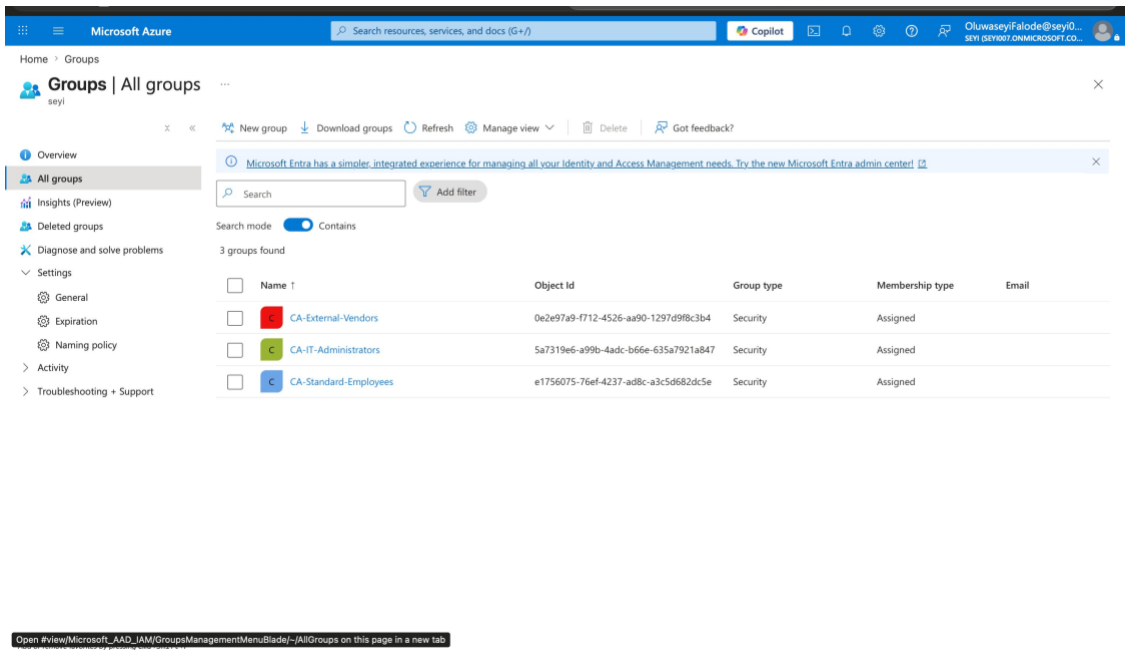


Figure 2 — Security groups: CA-Standard-Employees, CA-IT-Administrators, CA-External-Vendors

CA-Standard-Employees — Members

Test Employee assigned as a direct User member of the CA-Standard-Employees group.

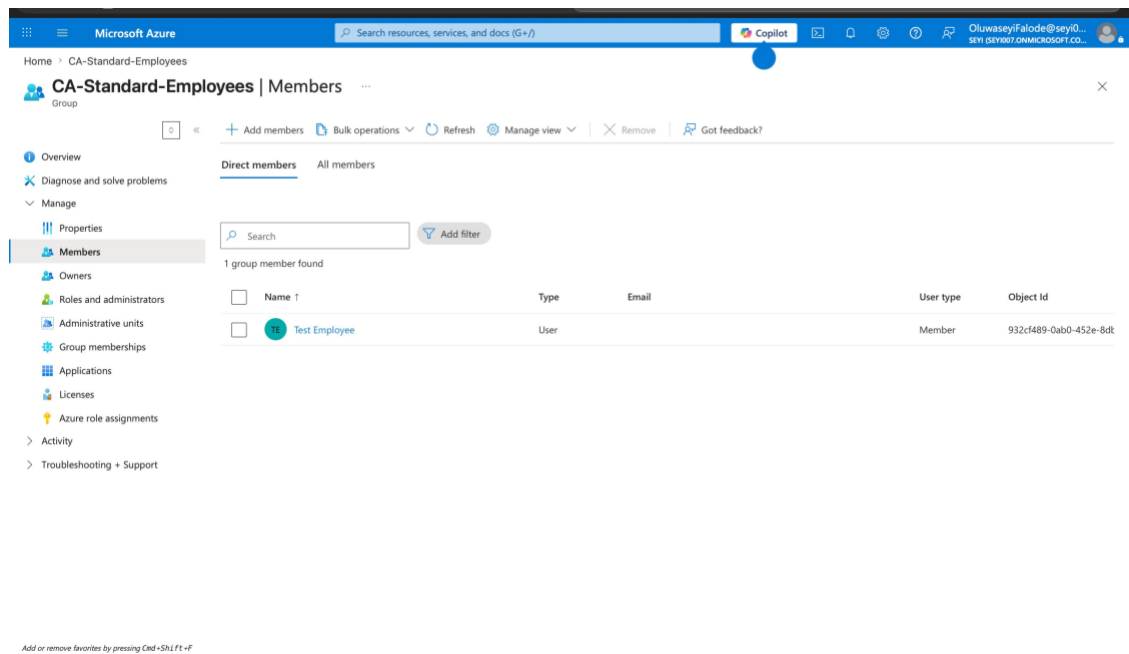


Figure 3 — CA-Standard-Employees group with Test Employee as direct member

CA-IT-Administrators — Members

Test Admin assigned as a direct User member of the CA-IT-Administrators group.

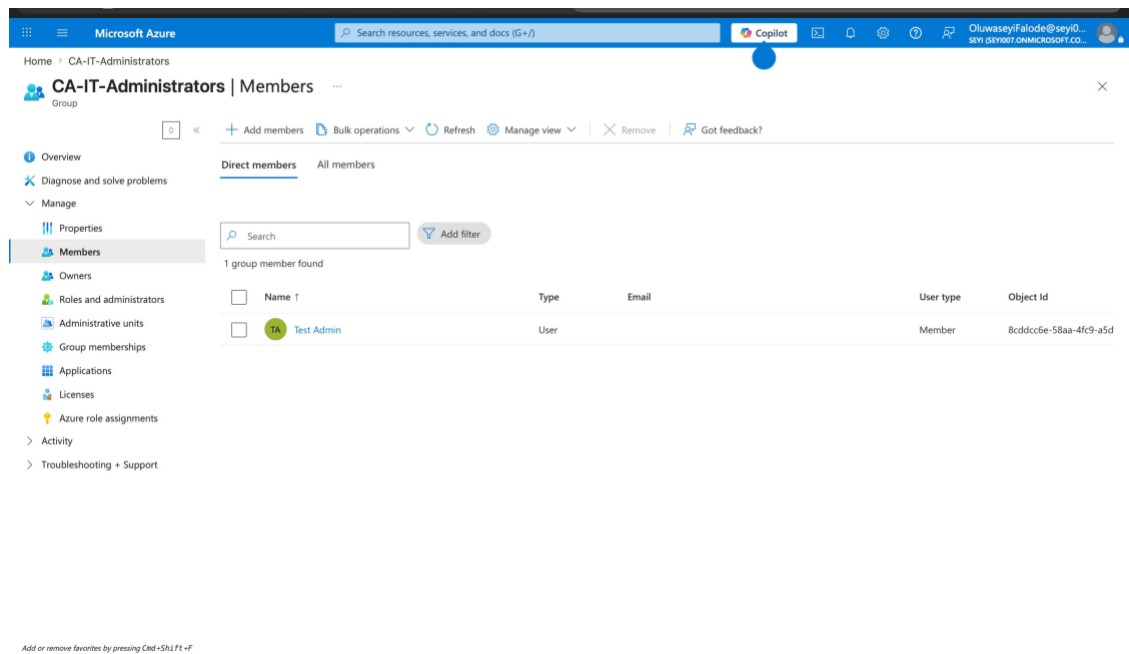


Figure 4 — CA-IT-Administrators group with Test Admin as direct member

Policies Deployed

CA-001 — Require MFA for All Users

Policy Name	Require MFA for All Users
Scope	All users → All cloud apps
Access Control	Require multifactor authentication

Why this matters: MFA is the single most effective control against account takeover. Microsoft research shows MFA blocks over 99% of account compromise attacks. Every user accessing any company application must verify their identity with a second factor.

CA-002 — Block Risky Locations

Policy Name	Block Risky Locations
Scope	All users → All cloud apps → Any network or location
Exclusion	Allowed-Countries-CA-US (Canada and United States)
Access Control	Block access

Why this matters: Login attempts from countries outside approved regions are blocked completely. A bank operating in Canada and the Americas has no legitimate reason to allow logins from unrelated regions. Stolen credentials used by attackers in foreign countries are stopped before authentication begins.

CA-003 — Require Compliant Device for Admin Portals

Policy Name	Require Compliant Device for Admin Portals
Scope	All users → Microsoft Admin Portals
Access Control	Require device to be marked as compliant

Why this matters: Admin portals are the highest value targets in any organization. Only devices enrolled in Microsoft Intune and verified as meeting security standards can access these portals.

CA-004 — Strict MFA for Admin Accounts

Policy Name	Strict MFA for Admin Accounts
Scope	CA-IT-Administrators → All cloud apps (Sign-in risk: Low, Medium, High)
Access Control	Require multifactor authentication

Why this matters: Admin accounts are the primary target of attackers. Admins get challenged at every risk level with zero exceptions. A compromised admin account can modify security settings, create users, and access everything.

CA-005 — Restrict Vendor Access

Policy Name	Restrict Vendor Access
Scope	CA-External-Vendors → Office 365
Access Control	Require multifactor authentication

Why this matters: Vendors are external parties. Limiting them to only Office 365 apps and requiring MFA means a compromised vendor account cannot reach Azure, admin portals, or sensitive financial systems.

Named Locations

A named location was created to define approved geographic regions, referenced in CA-002 as the exclusion.

Location Name	Type	Countries	Used In Policy
Allowed-Countries-CA-US	Countries (IP)	Canada, United States	CA-002-Block-Risky-Locations

Screenshots — Policies and Testing

All 5 Policies — Report-only Mode

The Conditional Access Policies dashboard showing all 5 user-created policies in Report-only state.

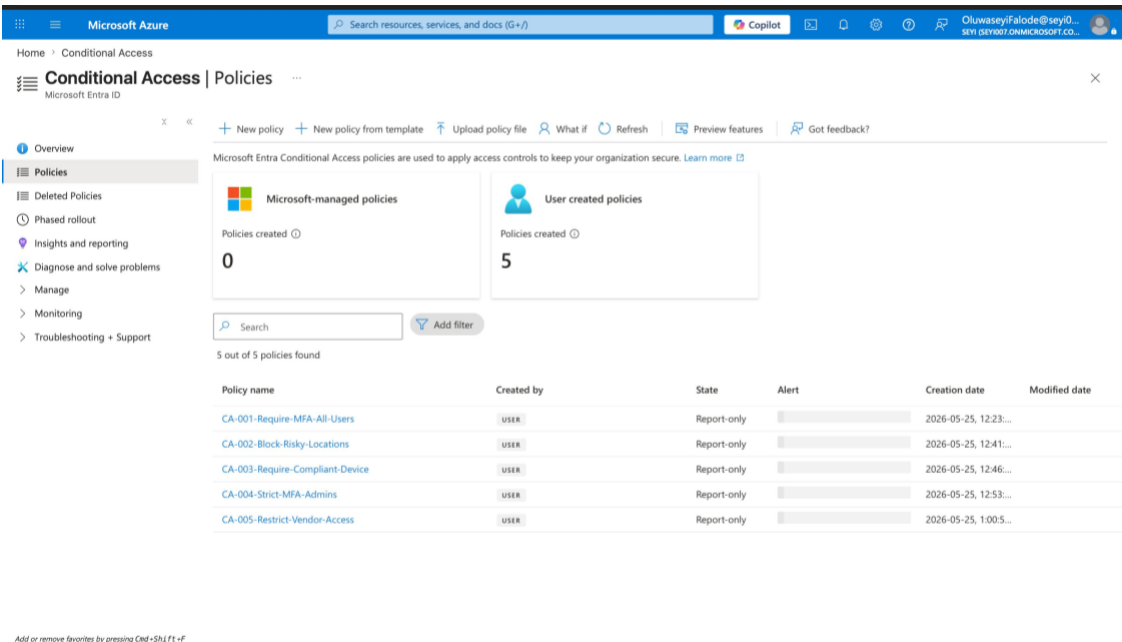
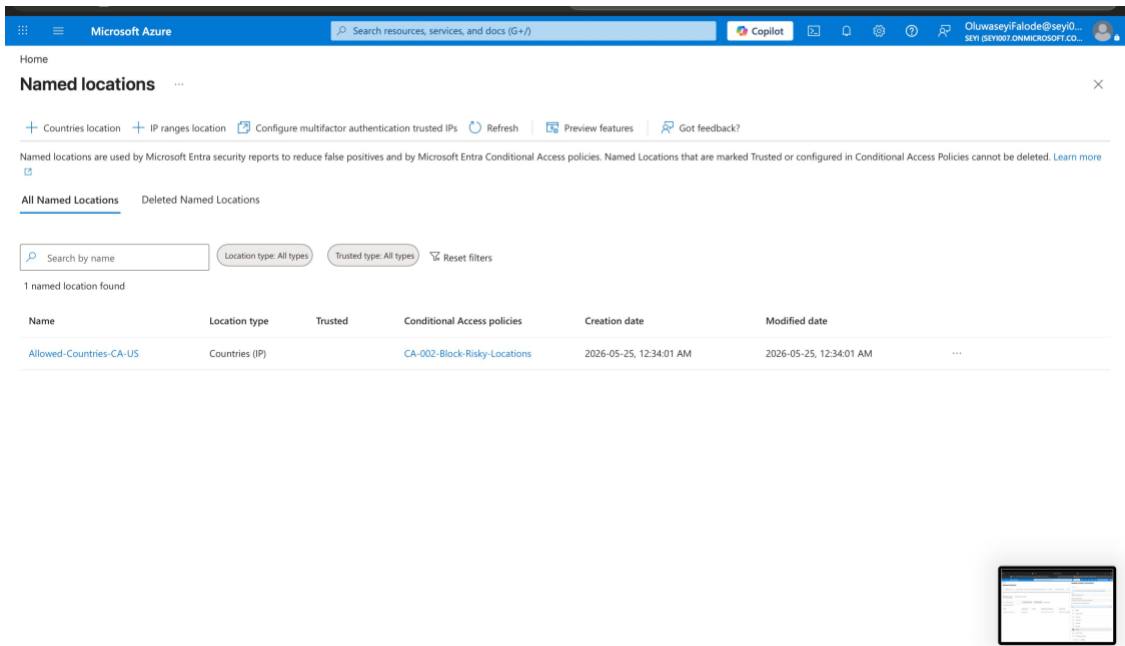


Figure 5 — All 5 Conditional Access policies in Report-only mode

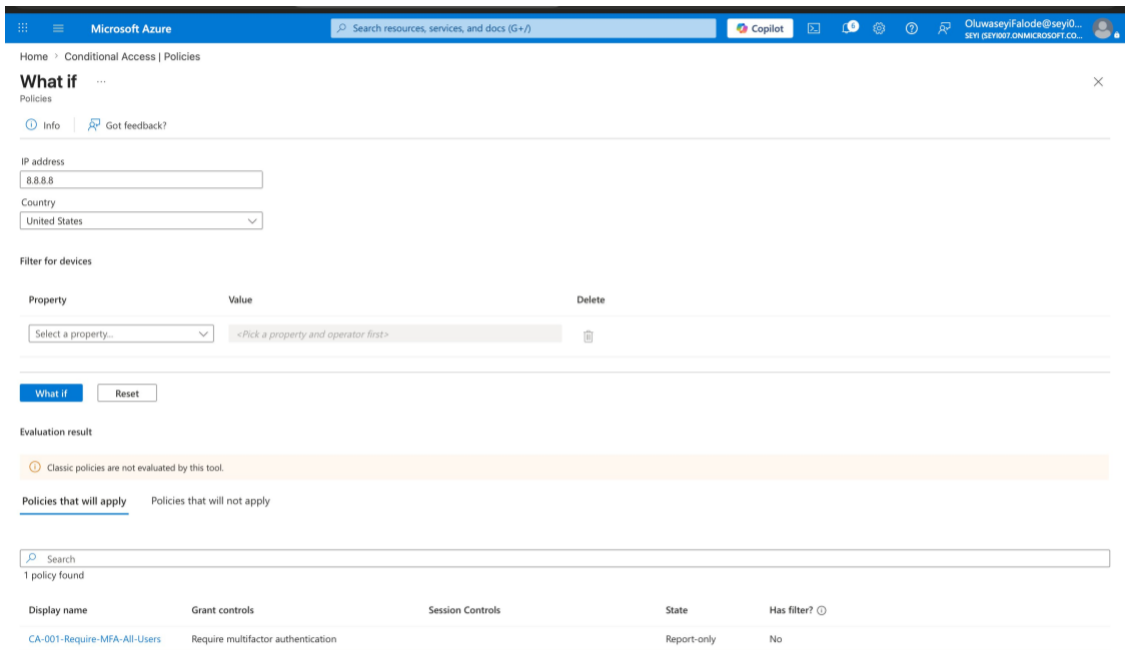
Named Locations

The Allowed-Countries-CA-US named location linked to CA-002, using country-based IP geolocation.



What If Test — US Login (MFA Triggered)

Test Employee logging in from IP 8.8.8.8 (United States). Result: CA-001 applies and requires MFA. Location policy correctly does not apply because the US is in the allowed countries list.



What If Test — Germany Login (Blocked)

Test Employee logging in from IP 185.220.101.1 (Germany). Result: Both CA-001 (MFA) and CA-002 (Block) apply. This login would be completely blocked in a live environment.

The screenshot shows the Microsoft Azure 'What if' tool interface. At the top, there's a search bar and a user profile. Below, the 'What if' section has a search bar and a 'Got feedback?' link. The main input area shows the IP address '185.220.101.1' and the country 'Germany'. Below this, there's a 'Filter for devices' section with a 'Property' dropdown and a 'Value' field. The 'What if' button is highlighted. The 'Evaluation result' section shows a message: 'Classic policies are not evaluated by this tool.' Below this, there's a section for 'Policies that will apply' and 'Policies that will not apply'. The 'Policies that will apply' section shows a table with 2 policies found.

Display name	Grant controls	Session Controls	State	Has filter?
CA-001-Require-MFA-All-Users	Require multifactor authentication		Report-only	No
CA-002-Block-Risky-Locations	Block access		Report-only	No

Figure 8 — What If result: Germany login triggers MFA + Block

Key Concepts Demonstrated

- Conditional Access policy design for a regulated financial institution
- Named location configuration using country-based IP geolocation
- User segmentation using security groups for targeted, scalable policy application
- Report-only mode deployment following enterprise change management best practices
- What If tool usage for pre-enforcement policy validation
- Principle of least privilege applied at the application level for vendor accounts
- Proportional security controls — stricter access controls for higher sensitivity resources
- Zero Trust identity layer — never trust, always verify, regardless of network location

Skills Applied

Microsoft Entra ID · Conditional Access · Identity and Access Management · Zero Trust Architecture · MFA Enforcement · Geo-blocking · Privileged Access Management · Microsoft Intune · Security Group Design · Enterprise Policy Framework

Oluwaseyi Michael Falode

Cybersecurity and Cloud Security Engineer | Toronto, ON

[linkedin.com/in/oluwaseyi-falode](https://www.linkedin.com/in/oluwaseyi-falode) | github.com/seyifalode-cmd | seyi.falode@yahoo.com